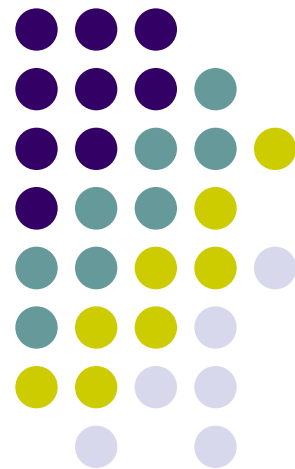


网络空间安全治理 Cyberspace Security Governance



邓小龙
北京邮电大学
2023年09月



第二章

网络空间和网络安全



目录

- 第一节 网络空间的定义
- 第二节 网络空间的分层
- 第三节 网络空间安全的定义
- 第四节 网络空间安全治理的定义

第一节

网络空间的定义



信息安全概念的出现

- “网络空间”的定义来自于我们传统意义上说的“信息安全”，但是又有别于“信息安全”；
- 信息安全可以追溯至二战时期；
- 直到20世纪40年代，信息安全和通信保密才进入学术界的视野。(DES|RSA)
- 20世纪50年代，相关科技文献中开始出现“信息安全”一词；
- 20世纪90年代，“信息安全”一词已经陆续出现在各国和地区的政策文献中，相关的学术研究文献也逐步增加。

□ 方滨兴. 论网络空间主权[M], 北京:科学出版社. 2007年9月1日。(书籍)

□ 方滨兴, 邹鹏, 朱诗兵. 网络空间主权研究[J]. 中国工程科学, 2016, 18(6):1-7.

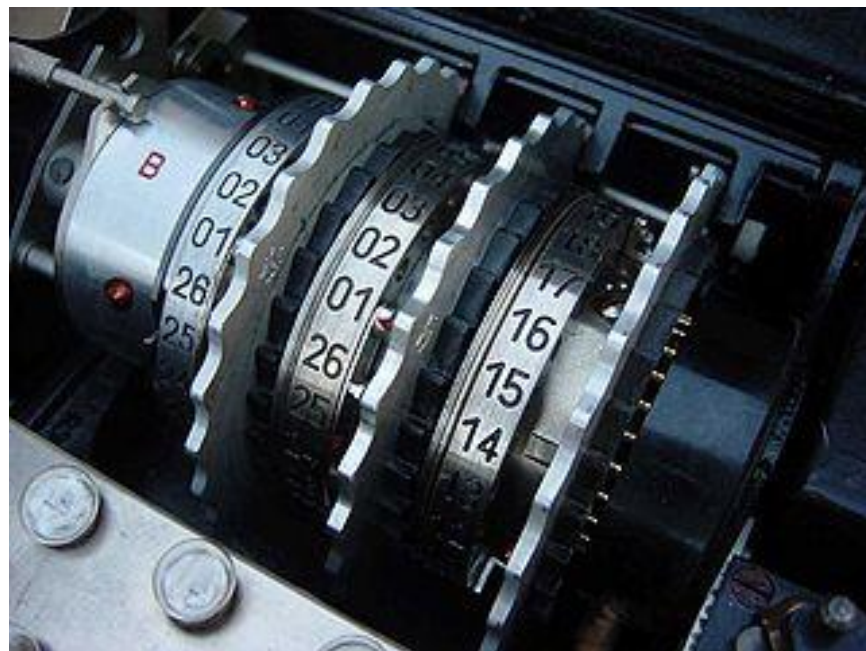
密码斗争实例（1）

二战中，英国破译德国的ENIGMA密码机

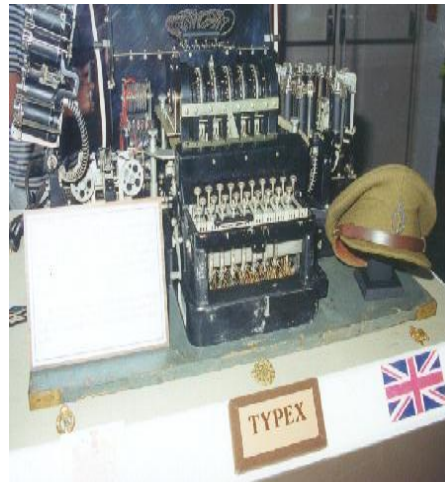


转子

- 机械系统包括了一个包含了字母与数字的键盘，相邻地排列在一个轴上的一系列名为“转子”的旋转圆盘,在每次按键后最右边的转子都会旋转，并且有些时候与它相邻的一些转子也会旋转。转子持续的旋转会造成每次按键后得到的加密字母都会不一样。



20世纪早期密码机



<http://hem.passagen.se/tan01/>



Hagelin CX-52



密钥的可能性

三个转子不同的方向组成了 $26 \times 26 \times 26 = 17576$ 种可能性；

三个转子间不同的相对位置为 6 种可能性；

连接板上两两交换 6 对字母的可能性则是异常庞大，有 100391791500 种；

于是一共有 **$17576 \times 6 \times 100391791500$**
这样庞大的可能性，换言之，即便能动员大量的人力物力，要想靠“暴力破译法”来逐一试验可能性，那几乎是不可能的。而收发双方，则只要按照约定的转子方向、位置和连接板连线状况，就可以非常轻松简单地进行通讯了。这就是“恩尼格玛”密码机的保密原理。

- “谜”（**ENIGMA**）密码最初是由一个叫胡戈·科赫的荷兰人发明的。
- 起初主要提供给想保护自己生意秘密的公司使用，但其商业的销路一直不理想。后来德国人将其改装为军用型，使之更为复杂可靠。德国海军于**1926**年开始使用“**ENIGMA**”，陆军则于**1928**年开始使用。
- **1933**年，纳粹最高统帅部通信部决定将“**ENIGMA**”作为德国国防军新式闪击部队的通信装置。德国人在战争期间共生产了大约**10**多万部“谜”密码机。
- **1940**年，经过盟军密码分析学家的不懈努力，“恩尼格玛”密码机被动攻破，盟军掌握了德军的许多机密，而德国军方却对此一无所知。

密码斗争实例（2）

日美密码战：二战中，日本海军使用的“紫密”密码早被美军破译，却没有及时更换，这样导致了中途岛事件。

日期：1942年6月4日—6月7日

地点：中途岛附近海域

参战方：美国指挥官：法兰克·弗莱彻海军中将；雷蒙德·斯普鲁恩斯海军少将

兵力：3艘航空母舰，约50艘支援战舰

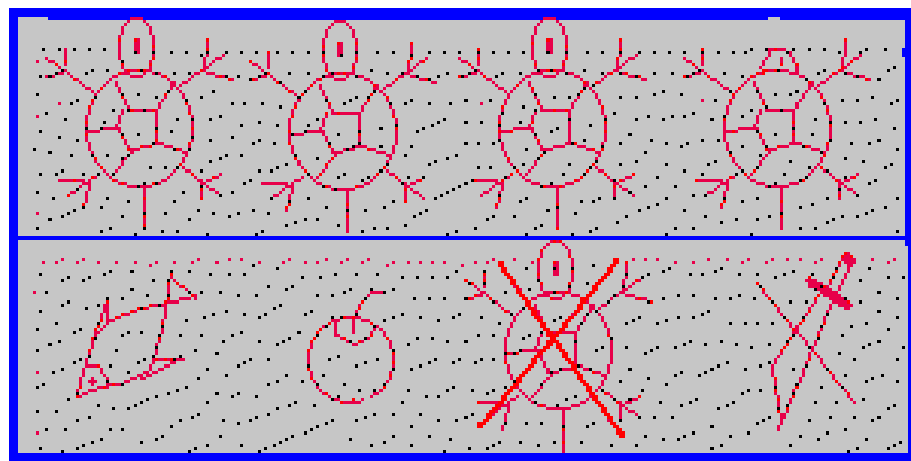
日本 指挥官：山本五十六海军大将；南云忠一海军中将

兵力：4艘航空母舰，7艘战列舰，约150艘支援战舰

损失/伤亡：美国：1艘航空母舰，1艘驱逐舰，147架飞机，307人阵亡

日本：4艘航空母舰，1艘重巡洋舰，332架飞机(包括备用机)，2,500人阵亡

- 传说，古时候有一对夫妻，男的名叫李石匠，女的叫张小花。李石匠靠手艺赚钱，张小花在家纺纱织布。一年，李石匠参加修建石桥，因工程紧张，十一个月也没回家一次。张小花独自在家只有纺车做伴。一天石匠工地回来一个工友路过她家，她托这个工友给丈夫带去一封书信。-另一个例子 德云社相声 《山西家信》



归，归，归！速归！如果（鱼果）不归，一刀两断

信息的安全威胁

- 🌍 **自然威胁：** 自然灾害、恶劣的场地环境、电磁辐射和电磁干扰、网络设备自然老化。
- 🌍 **人为威胁：** 恶意的或无恶意的用户(主要研究)

信息系统面临的威胁

✓ 计算机 物理威胁

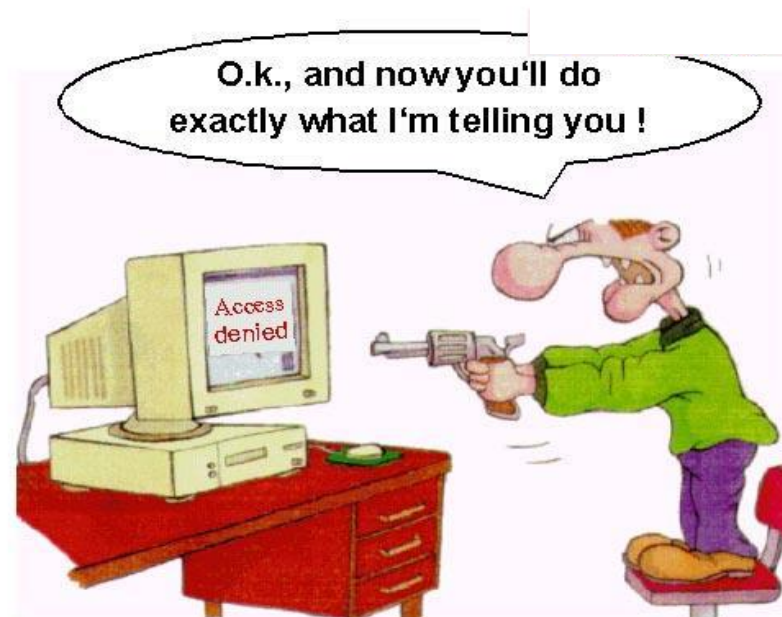
依附载体

✓ 数据 表现形式
漏洞、病毒、木马

✓ 程序 处理工具

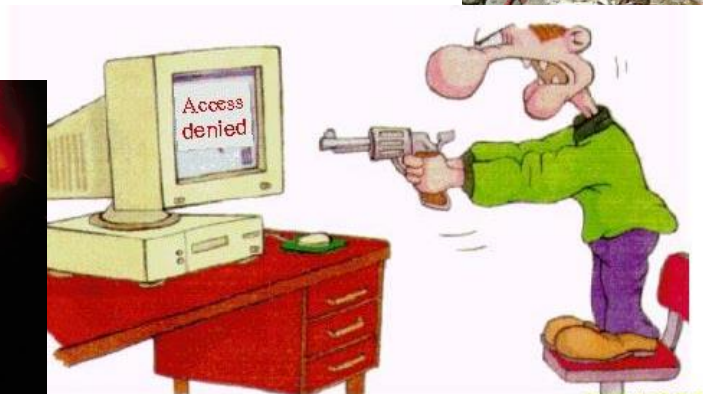
✓ 网络 网络攻击
传递媒介

✓ 管理 管理漏洞
人为因素



按照来源的信息系统威胁

- 自然灾害威胁
- 滥用性威胁
- 有意人为威胁





信息安全十大领域

- 总部设在美国佛罗里达州的国际信息系统安全认证组织(**International Information Systems Security Consortium**) 将信息安全划分为十大领域，包括
 - ——物理安全
 - ——安全结构和模式
 - ——通信和网络安全
 - ——密码学领域
 - ——操作安全
 - ——商务连续和灾害重建计划
 - ——应用和系统开发
 - ——访问控制领域
 - ——安全管理实践
 - ——法律侦察和道德规划

网络空间安全概念出现的背景

- 近年来，随着全球互联网的快速发展和社会信息化程度的快速推进，相比物理的现实社会，网络空间中的数字社会在各个领域所占的比重越来越大。

- 数字化社会的数量增长带来了质量的变化，以数字化、网络化、智能化、互联化、泛在化为特征的网络社会，为信息安全带来了新技术、新环境和新形态。

- 信息安全主要体现在现实物理社会的情况发生了变化，开始更多地体现在网络安全领域，反映在跨越时空的网络系统和网络空间之中，反映在全球化的互联互通之中。

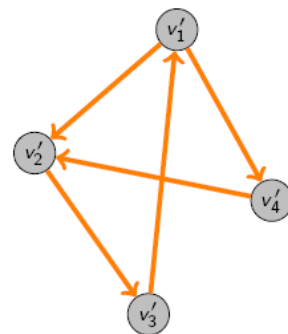




从上面的分析可知，“网络空间安全”的定义来源于在“网络空间”中的信息安全涵义的外延，因此必须先弄明白“网络空间”(**cyberspace**)这个概念的内涵与外延。

“网络空间”来自于“网络”(**cyber**)。

网络的定义



- 一般认为，网络是由节点和连接边构成，用来表示多个对象及其相互联系的互连系统。
- 现实中的信息网络，可以抽象地概括为：将各个孤立的“端节点”（信息的生产者和消费者），通过“连接边”（物理或虚拟链路）将之连接在一起，进而实现各端节点间通过“交换节点”进行转发，以实现载荷在端节点之间进行交换。
- 其中“载荷”是网络中数据与信息的表达形式，如电磁信号、光信号、量子信号、网络数据等。
- 网络的四个基本要素：**端节点、交换节点、连接边、载荷**。
- 该定义反映出“网络”的含义很广泛，不仅互联网符合这一特征，电信网、物联网、传感网、工控网、广电网等各类电磁系统所构成的信息网络都符合“网络”的描述，因而对网络的讨论就不再是仅限于互联网这么狭窄。

网络与网络空间

- 网络（Network）、互联网（Internet）和网络空间（Cyberspace）
 - network多指物理结构意义上的网络。
 - internetworks（互联的网络）——Internet（互联网）
 - “cyberspace”源于“cybernetics（控制论）”，最早出现在网络朋克（cyberpunk）科幻作家威廉·吉布森（William Gibson）的小说《Neuromancer（神经漫游者）》（1986年）中，在1990年代开始流行，常用于指基于计算机网络的**通信环境**。
 - 《网络安全法》：网络，是指由计算机或者其他信息终端及相关设备组成的按照一定的规则和程序对信息进行收集、存储、传输、交换、处理的系统。

□ 谢永江. 网络安全法学[M], 北邮出版社. 2017年。(书籍)

网络空间的直观定义

- 网络空间*是一种人造的电磁空间，其以终端、计算机、网络设备等为载体，人类通过在其上对数据进行计算、通信来实现特定的活动。
- 在这个空间中，人、机、物可以被有机地连接在一起进行互动，可以产生影响人们生活的各类信息，包括内容、商务、控制信息等。

*方滨兴. 论网络空间主权[M], 北京:科学出版社. 2007年9月1日。

网络空间-院士定义

- 网络空间：是一种人造的电磁空间，其以互联网、各种电信网与通信系统、各种传播系统与广电网、各种计算机系统、各类关键工业设施中的嵌入式处理器和控制器等信息通信技术基础设施为载体，用户通过在其上对数据进行创造、存储、改变、传输、使用、展示等操作，以实现特定的信息通信技术活动。（方滨兴院士）



图片来源：视觉中国 www.vcg.com

网络空间的学术定义（1）

- 网络空间是人类通过**网络角色**，依托**信息通信技术系统**来进行**广义信号交互**的人造**活动空间**。



网络空间的学术定义（2）

- **网络角色**是指产生、传输广义信号的主体，反映的是人类的意志；
- **信息通信技术系统**包括互联网、电信网、无线网、移动网、广电网、物联网、传感网、工控网、卫星网、数字物理系统（**CPS**）、在线社交网络、计算系统、通信系统、控制系统等光电磁或数字信息处理设施；
- **广义信号**是指基于光、电、声、磁等各类能够用于表达、存储、加工、传输的电磁信号，以及能够与电磁信号进行交互的量子信号、生物信号等信号形态；这些信号通过在信息通信技术系统中进行存储、处理、传输、展示而成为信息；
- **活动**是指用户以信息通信技术为手段、对广义信号进行操作作用以表达人类意志的行为；操作包括产生信号、保存数据、修改状态、传输信息、展示内容等，可称为“信息通信技术活动”。

网络空间的动态“四要素”

- 网络空间的四要素：
虚拟角色、平台、数据、活动
- 虚拟角色强调主体（即用户）
- 平台强调载体（即基础设施）
- 数据强调客体（即载荷）
- 活动强调行为

网络空间的“垂直”构成要素

1、物理设备

- 计算机、路由器、传输设备、终端设备

物理层

2、软件协议

- 操作软件、应用软件、网络协议

逻辑层

3、信息数据

- 以光、电、声、磁等信号形态，以及量子信号、生物信号等能够与电磁信号进行交互的信号形态生成、存储、处理、传输、展示的信息。

数据层

4、网络主体

- 网民、互联网企业、社会团体NGO、政府等

社会层

5、网络行为

- 信息通信技术活动、社交活动

网络空间的属性

- 网络空间的虚拟性与现实性
 - (1) 空间：没有三维空间；物理设备
 - (2) 主体：匿名，隐藏身份：网民
 - (3) 客体：虚拟财产；信息
 - (4) 行为：行为由代码构成；信息行为
- 网络空间的社会性
 - 网民——互动——网络社会
 - 每个上网者和网上的网站和网页都是互联网的节点；节点连接节点，交织成网，形成网络节点联系的体系，构成互联网上的社会交往体系，即网络社会。
 - 网络社会是网络空间与现实社会的融合。



Peter Steiner,
1993

□ 谢永江. 网络安全法学[M], 北邮出版社. 2017年。(书籍)

三、网络空间与全球公域

- “全球公域”主要指那些国家管辖范围之外的自然资产，传统上主要包括公海及其上空、外层空间和南极洲。
- 2011年4月，北约研究报告《确保进入全球公域》（Assured Access to the Global Commons）中所指的“全球公域”包括海洋、天空、太空和网络。
- 美国极力主张网络空间为全球公域
 - 2005年美国国防部出台的《国土防御与民间支持战略》就将网络空间视为全球公域（the global commons of space and cyberspace）。
 - 2010年2月，美国国防部发布的《四年防务评估报告》将网络空间与海洋、天空、太空并列为四大公域。
 - 2015年的美国《国家安全战略》中提出，“应当采取集体行动，确保对共享空间（sharing space）——网络、太空、天空、海洋——的进入。”

网络空间不应是全球公域

- 1、组成网络空间的物理设备设施是在各国主权管辖之下。
- 2、网络空间中的信息自由不是因为它是一个全球公域，而是因为各国免除或放松了信息出入境管制。
- 3、网络空间与传统全球公域最大的不同是网络空间具有社会性。
- 4、网络的互联互通性 or 无国界性并不意味着网络空间就是一个全球公域。
- 5、全球公域向来都是有利于技术强国，不利于后进国家。只有掌握了必要技术能力的国家，才能够为了政治、经济、科学、文化以及军事目的而出入其中并加以利用。
- 6、美国将网络空间作为全球公域有利于确保美国全球霸权地位和推销美国价值观。

第二节

网络空间的分层



网络安全的三大治理领域

■ 网络安全与国家安全及社会生活息息相关，引发各国高度重视和积极应对，网络安全是全球互联网治理重要议题

进展

关键基础设施保护、社交媒体管控和数据治理是网络安全治理三大领域

- 金融、交通、能源、通信等关键基础设施成为网络攻击的重点对象
- 社交媒体发展挑战各国政治安全和意识形态。剑桥分析事件等引发系列举措
- 全球数据治理聚焦个人信息保护和数据跨境流动；GDPR生效波及全球

格局

面对日益严峻的网络安全形势，各方在竞争与博弈中向加强合作迈进

- 各国加大国际协作和联合执法力度，协调各国力量共同应对网络安全问题
- 《巴黎网络空间信任和安全倡议》出台
- 多国意识到内容管理必要性，对极端主义、恐怖主义、虚假信息等管控，加强对互联网平台的监管
- 发达国家强化数据保护和本地化并赋予本国域外管辖，其他国家纷纷仿效

PARIS CALL
FOR TRUST AND SECURITY
IN CYBERSPACE
11 • 12 • 2018



CBPRs
CROSS BORDER PRIVACY RULES

网络空间安全的4 层次模型

- 设备层的安全应对在网络空间中信息系统设备所面对的安全问题；
- 系统层的安全应对在网络空间中信息系统自身所面对的安全问题；
- 数据层的安全应对在网络空间中处理数据的同时所带来的安全问题；
- 应用层的安全应对在信息应用的过程中所形成的安全问题。

应用层的安全

数据层的安全

系统层的安全

设备层的安全

第三节

网络空间安全的定义



网络空间安全概念的兴起

- **20 世纪90 年代**以来，信息安全开始向网络安全聚焦，经历了一个逐步发展和逐步强化的过程。在**20 世纪90 年代**广泛使用的“信息安全”一词，在进入**21 世纪**的十多年中，已逐步与“网络安全”和“网络空间安全”并用，而网络安全与网络空间安全的使用频度不断增加，这在发达国家的相关文献中尤为突出。
- 尽管信息安全至今仍然是人们常用的概念，但随着**2002 年**世界经合组织通过了关于信息系统和网络安全的指南文件，特别是**2003 年**美国发布了网络空间战略的国家文件，“网络安全”和“网络空间安全”开始成为较之“信息安全”更为社会 and 业界所聚焦和关注的概念，在理论研究和实践中也使用得更加频繁。

国外的网络安全定义

- 《澳大利亚网络安全战略》（2009）将“网络安全”定义为：与通过电子或类似的方法处理、储存和传输的**信息**的保密性、可用性和完整性有关的**措施**。
- 美国《联邦信息安全管理法》(FISMA)中，“信息安全”被定义为：“保护信息和信息系统以避免未经授权的访问、使用、泄漏、破坏、修改或者销毁，以确保信息的完整性、保密性和可用性。”
- 日本《网络安全基本法》（2014）第2条将“网络安全”定义为：“为保障以电子化方式、磁气化方式及其他以人的知觉所无法认知的方式记录或发送、传播信息，保障该信息不被泄露、销毁、毁坏等任何为信息安全管理而进行的**必要措施**，以及确保信息系统及信息通信网络的安全性和可信性而采取的**必要措施**（含对联通信息通信网络及制作成电磁式记录形式的记录媒体的电子计算机进行的不正当活动的损失预防所需要采取的**必要措施**），而且**这些措施皆维持恰当的状态**。”
- 《德国网络安全战略》（2011）将网络安全定义为：（全球）网络安全是指一种IT安全状态的**期望目标**，即全球网络空间风险降低到可接受的**最小程度**。因此，德国网络安全是指一种IT安全状态的期望目标，即德国网络空间风险降低到可接受的最小程度。（德国）网络安全是相配的和适当的**措施的总和**。

网络空间安全的定义

- 从信息论角度来看,系统是载体,信息是内涵。因此从定义上而言,网络空间是所有信息系统的集合,是人类生存的信息环境,人在其中与信息相互作用相互影响。
- 网络空间安全则是指“在网络空间中广泛存在的信息系统,可能对网络空间(Cyber)、物理空间(Physical)和社会空间(Society)造成的安全问题”,例如常见的终端安全、网络内容安全、网络舆情监测等。



网络空间安全的理解

- 从网络空间安全的内涵与外延而言，网络空间安全可以指称信息安全或网络安全，但侧重点是与陆、海、空、太空等并行的空间概念，并一开始就具有军事性质；
- 与信息安全相比较，网络安全与网络空间安全反映的信息安全更立体、更宽域、更多层次，也更多样，更能体现出网络和多空间的特征，并与其他安全领域更多地渗透与融合。

[11] 罗军舟, 杨明, 凌振,等. 网络空间安全体系与关键技术[J].

中国科学:信息科学, 2016, 46(8):939.

网络空间安全的理解

- 国内学者纷纷开始探讨网络空间安全的内涵并梳理其中涉及的研究领域,为构建网络空间安全研究体系提出了一些方案和建议。
- 方滨兴院士[1]提出了网络空间安全的4层次模型,包括设备层的安全、系统层的安全、数据层的安全以及应用层的安全,同时列出了信息安全、信息保密、信息对抗、云的安全、大数据、物联网安全、移动安全、可信计算8个研究领域,并分析了这些领域在不同层面上面临的安全问题及对应的安全技术。
- 李晖(西电)等[2]则从学科人才培养的角度出发,分析了网络空间安全学科与相关一级学科的关系,并在此基础上提出了网络空间安全学科的3层知识体系,其中底层是网络空间安全基础理论,中间层包括物理安全、网络安全和系统安全,顶层是数据与信息安全。
- 李建华等[3]指出网络空间安全是一门新兴的交叉学科,包括网络空间安全基础、密码学及应用、系统安全、网络安全、应用安全5个研究方向,其中安全基础为其他方向的研究提供理论、架构和方法学指导,密码学及应用为系统安全、网络安全和应用安全提供密码机制。

网络空间安全的四项主要内容-芦

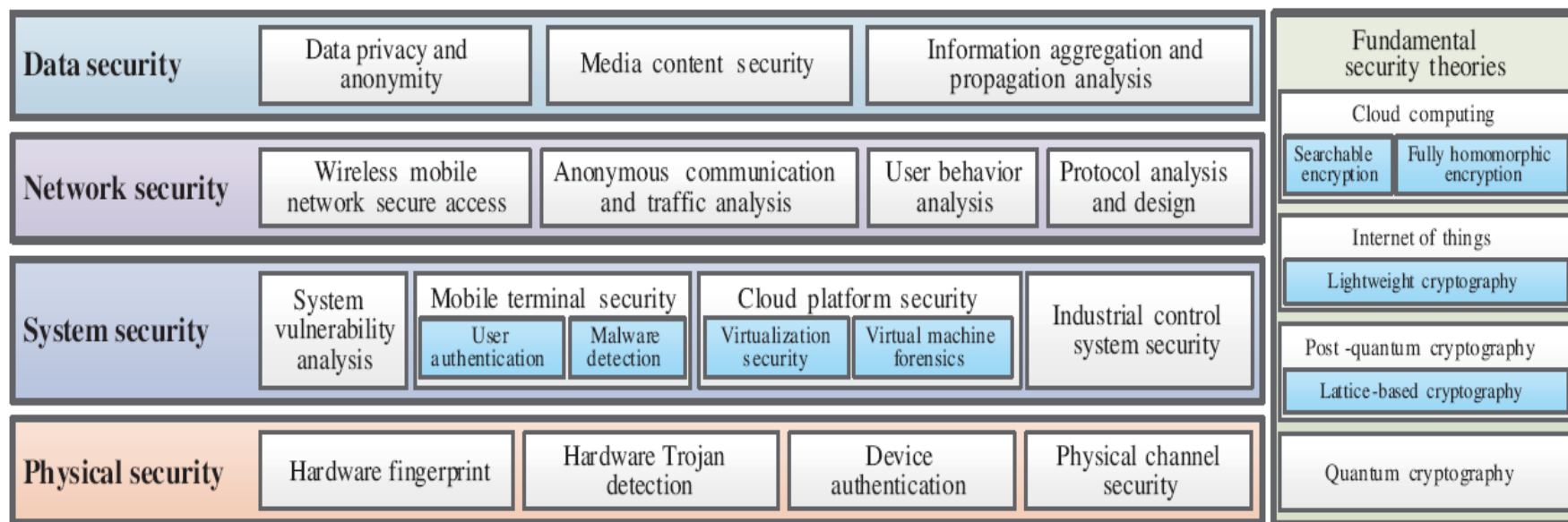


图 1 (网络版彩图) 安全研究层次体系及代表性研究方向

Figure 1 (Color online) Hierarchical security architecture and representative research areas

- [11] 罗军舟, 杨明, 凌振,等. 网络空间安全体系与关键技术[J]. 中国科学:信息科学, 2016, 46(8):939.

网络空间安全的四项主要内容

Physical security

Hardware fingerprint

Hardware Trojan
detection

Device
authentication

Physical channel
security

- 1.物理层安全
- 主要研究针对各类硬件的恶意攻击和防御技术,以及硬件设备在网络空间中的安全接入技术。
- 在恶意攻击和防御方面的主要研究热点有侧信道攻击、硬件木马检测方法和硬件信任基准等;
- 在设备接入安全方面主要研究基于设备指纹的身份认证、信道及设备指纹的测量与特征提取等。此外,物理层安全还包括容灾技术、可信硬件、电子防护技术、干扰屏蔽技术等。

[11] 罗军舟, 杨明, 凌振,等. 网络空间安全体系与关键技术[J].

中国科学:信息科学, 2016, 46(8):939.

物理层的安全保护方案

- 计算机网络通信线路屏蔽方案
- 主要物理隔离
- 物理隔离网闸隔离原理
- 设备和线路冗余方案
- 服务和账号安全规划
- 物理层安全管理工具的使用
- 数据容灾等级

物理层的线路窃听技术

- 搭线窃听
- 电磁泄漏窃听

计算机网络通信线路屏蔽

- 屏蔽

- ◆ 用金属网或金属板将信号源包围，利用金属层来阻止内部信号向外发射，同时也可以阻止外部信号进入金属层内部。

屏蔽双绞线和RJ-45水晶头的选择；
屏蔽同轴电缆的选择；
光纤网络的屏蔽

- 通信线路的屏蔽

- ◆ 采用屏蔽性能好的传输介质
- ◆ 把传输介质、网络设备、机房等整个通信线路安装在屏蔽的环境中

屏蔽机房和机柜的选择

计算机网络通信线路屏蔽

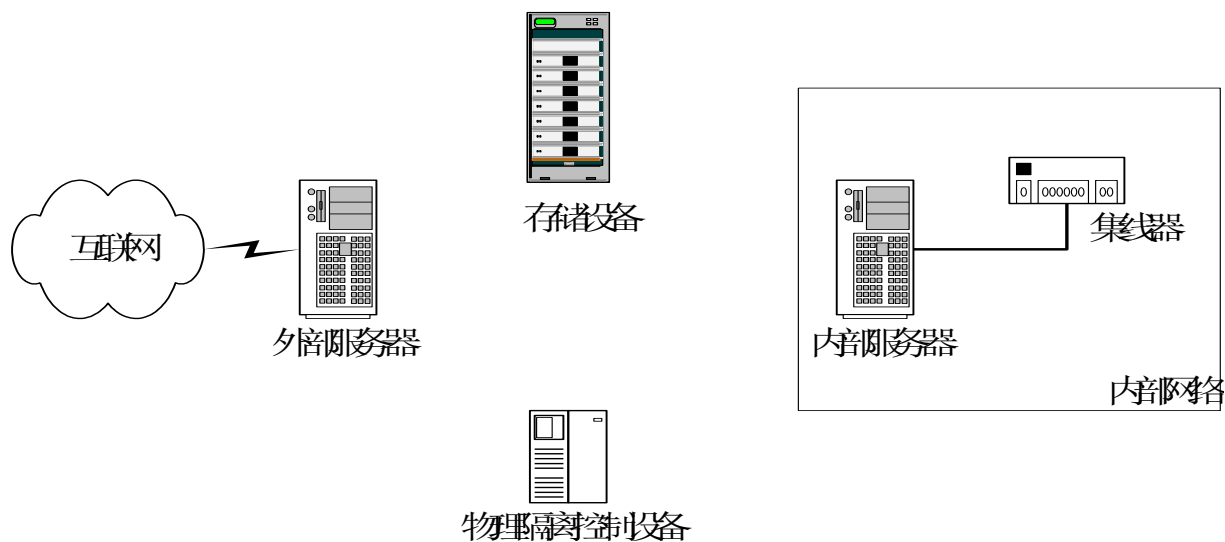
- WLAN无线网络的物理层安全保护
 - ◆ 将机房甚至整个公司屏蔽（成本过高）
 - ◆ WEP
 - ◆ WPA/WPA2

物理线路隔离

- 主要物理隔离产品
 - ◆ 物理隔离卡
 - ◆ 物理隔离集线器/交换机
 - ◆ 物理隔离网闸

物理线路隔离

- 物理隔离的指导思想与防火墙绝然不同：防火墙的思路是在保障互联互通的前提下，尽可能安全，而物理隔离的思路是在保证必须安全的前提下，尽可能互联互通。
- 一个典型的物理隔离方案（处于完全隔离状态）



物理线路隔离

- 物理隔离的定义

- ◆ 物理隔离技术的基本思想是:如果不存在与网络的物理连接,网络安全威胁便可大大降低。
- ◆ 物理隔离技术实质就是一种将内外网络从物理上断开,但保持逻辑连接的信息安全技术。

物理线路隔离

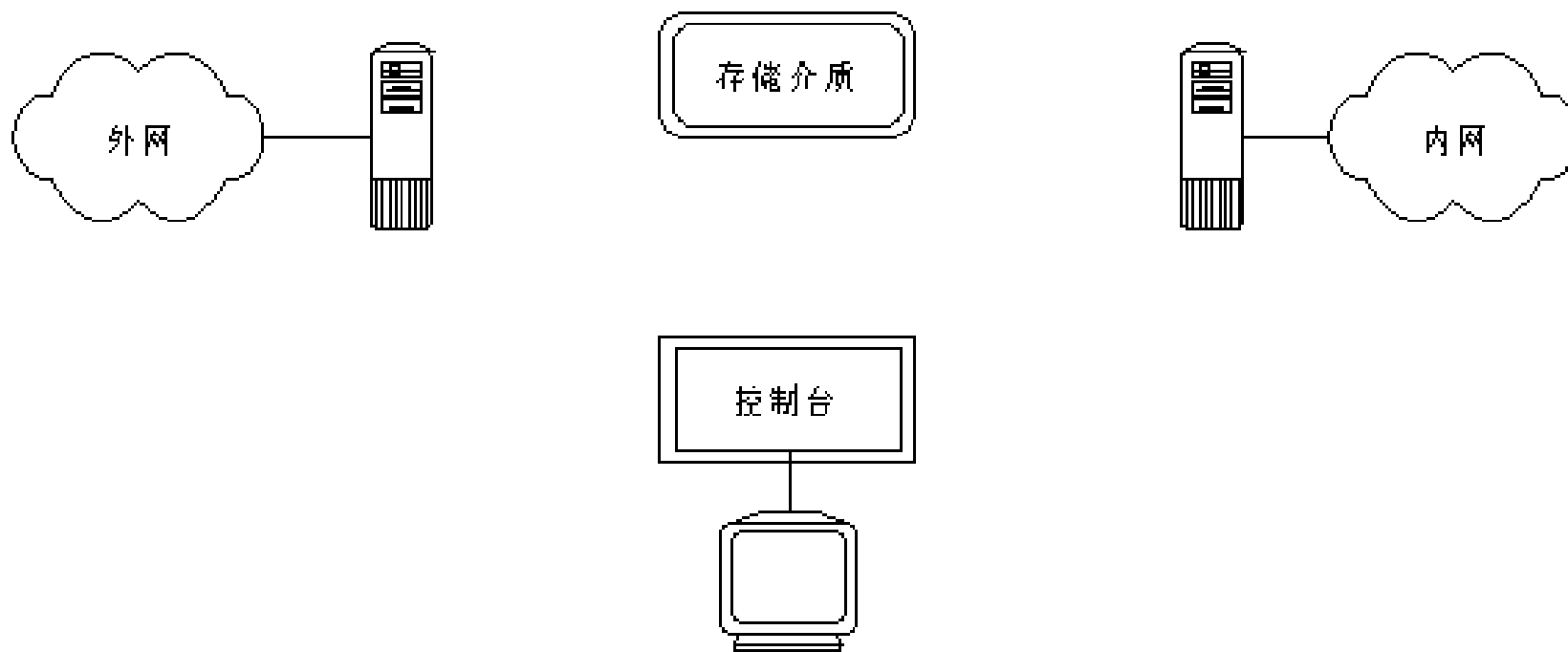
- 案例：电子政务
- 一般划分为3个安全等级不同的部分
 - 内部保密专用网络，传送保密信息
 - 业务网络，传送政府业务管理信息
 - Internet连接网络，建设网站或对外访问
- 保密网络要求跟其它部分物理隔离
- 其它部分可以在保证安全性情况下互连

物理线路隔离

- 案例：证券交易网
- 一般划分为3个安全等级不同的部分
 - 证券交易业务专用网络，传送证券业务信息
 - 企业内综合管理网络，传送办公、财务、VoIP等企业内部管理信息
 - Internet连接网络，建设网站或对外访问
- 交易网络首先要保证可靠性和安全性，跟其它部分物理隔离，必要时可以采用逻辑隔离方式连接
- 其它可以在保证安全性情况下互连

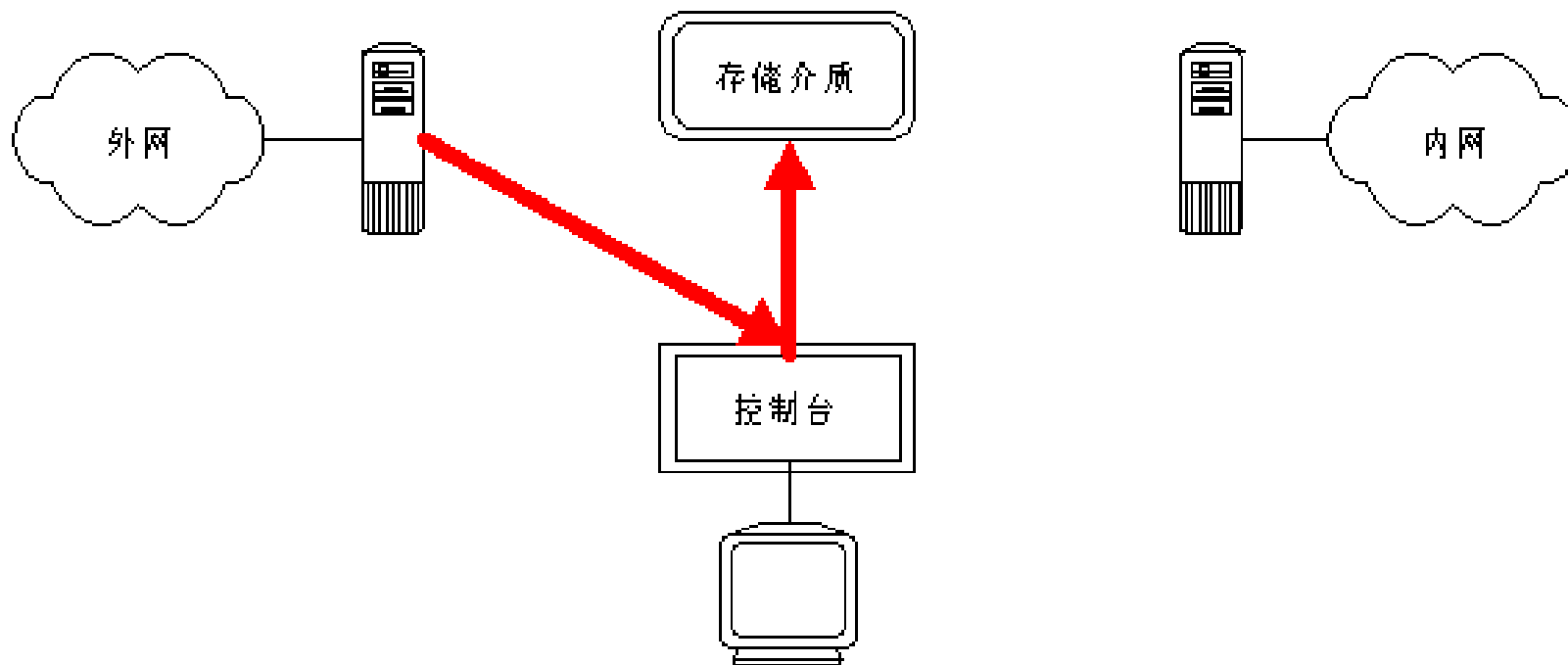
物理线路隔离

- 内、外网之间在没有通信要求情况下的断开状态



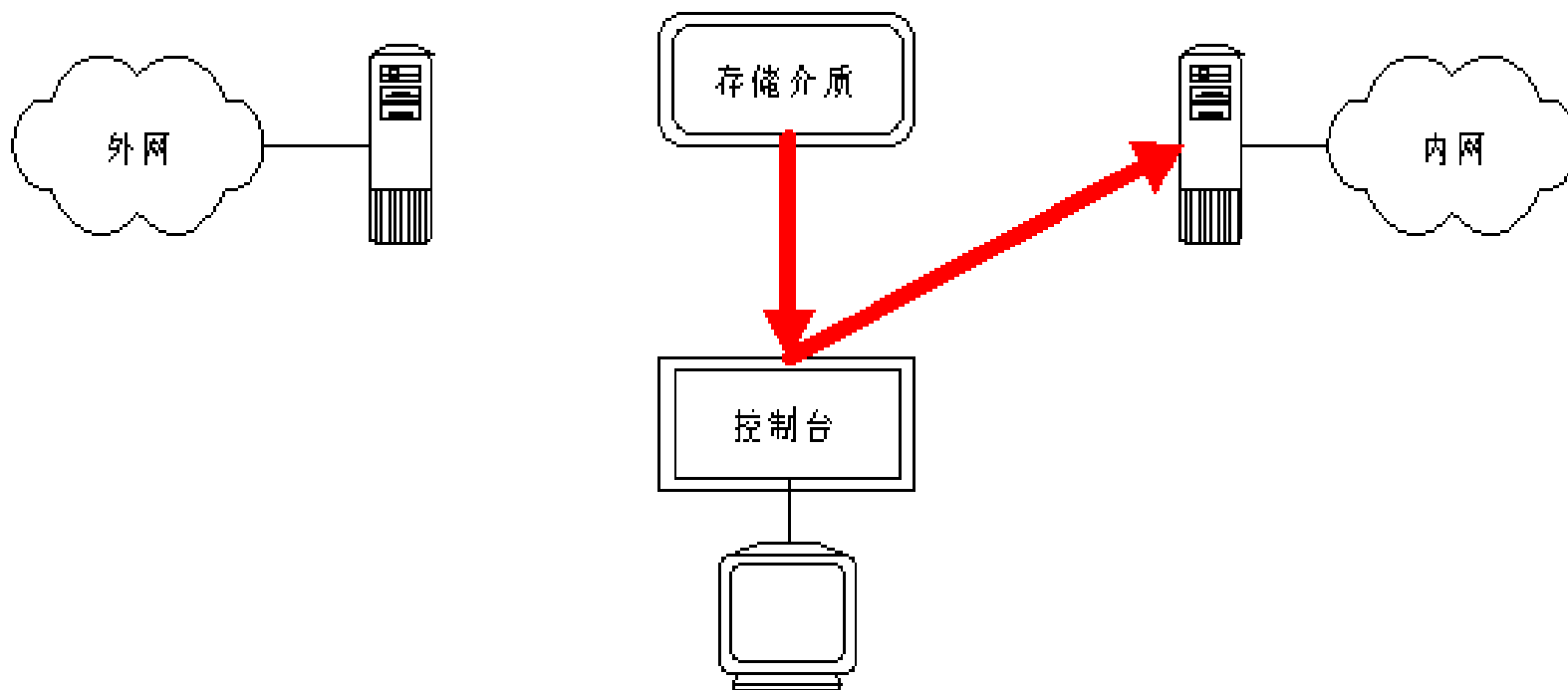
物理线路隔离

- 外网向内网发起非TCP/IP连接



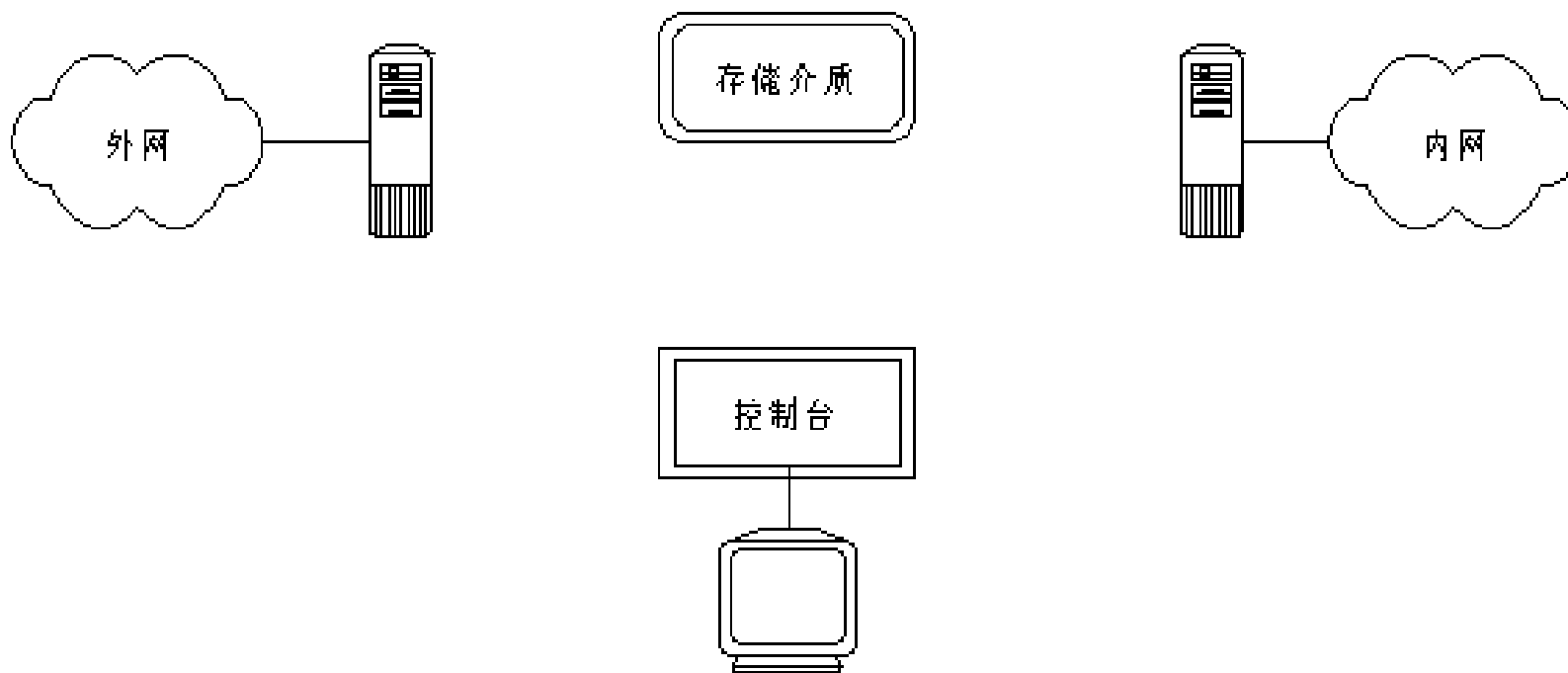
物理线路隔离

- 向内网转发数据



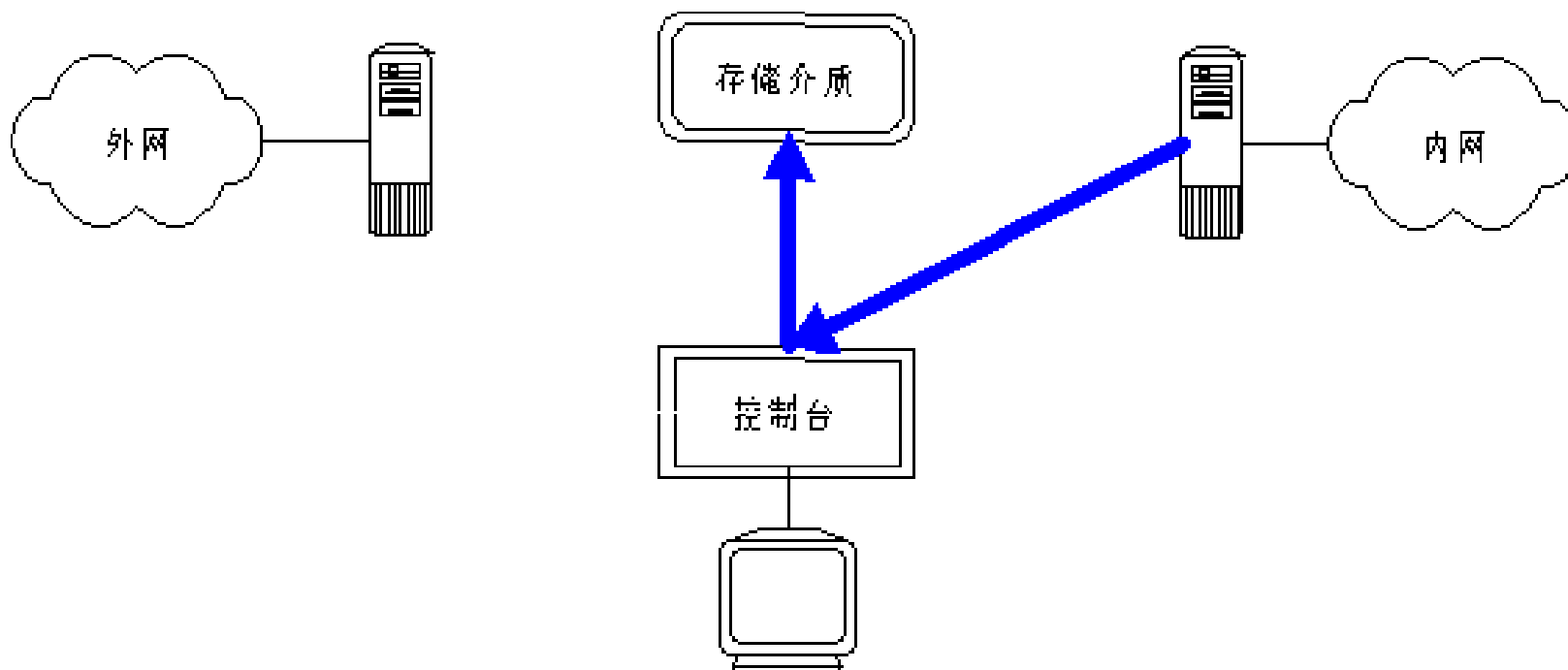
物理线路隔离

- 完成了外网向内网发送数据的全过程后



物理线路隔离

- 向外网发起非TCP/IP连接



物理线路隔离

- 这是一种隔离网络之间连接的专用安全技术。
- 这种技术使用一个可交换方向的电子存储池。存储池每次只能与内外网络的一方相连。通过内外网络向存储池拷贝数据块和存储池的摆动完成数据传输。
- 这种技术实际上是一种数据镜像技术。它在实现内外网络数据交换的同时，保持了内外网络的物理断开。

物理线路隔离

- 每一次数据交换，隔离设备经历了数据的接受，存储和转发三个过程。由于这些规则都是在内存和内核里完成的，因此速度上有保证，可以达到100%的总线处理能力。
- 物理隔离的一个特征，就是内网与外网永不连接，内网和外网在同一时间最多只有一个同隔离设备建立非TCP/IP协议的数据连接。其数据传输机制是存储和转发。
- 物理隔离的好处是明显的，即使外网在最坏的情况下，内网不会有任何破坏。修复外网系统也非常容易。

设备和线路冗余

- 提供备用的设备和线路
 - ◆ 网络设备部件冗余: 电源和风扇,网卡,内存,cpu,磁盘)
 - ◆ 网络设备整机冗余
 - ◆ 网络线路冗余

机房和账户安全管理

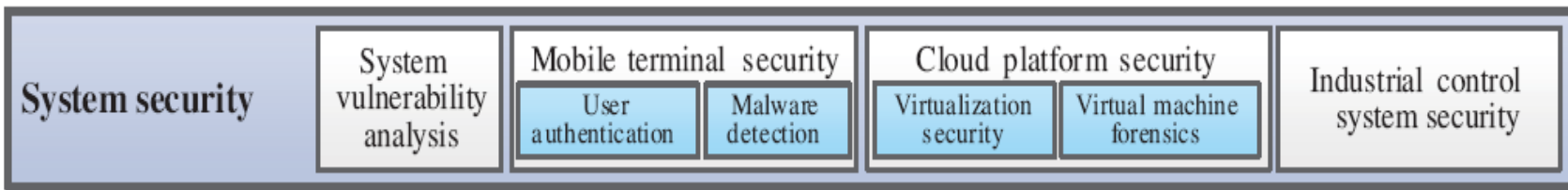
- 机房安全管理

- 账户安全管理

- ◆ 采取复杂性要求限制
- ◆ 限定最低和最高密码更改的频率和期限
- ◆ 限定两个周期密码可以禁止相同的最短历史
- ◆ 限定用户登陆时允许尝试的最多次数
- ◆ 要求拥护不得把账户信息以明文方式记录在任何地方
- ◆ 不得在有其他人在旁边时输入账户信息

通过“管理工具”_“本地安全策略”中的“帐户策略”的“密码策略”实现

网络空间安全的四项主要内容



- **2. 系统层安全**
- 包括系统软件安全、应用软件安全、体系结构安全等层面的研究内容,并渗透到云计算、移动互联网、物联网、工控系统、嵌入式系统、智能计算等多个应用领域,具体包括系统安全体系结构设计、系统脆弱性分析、软件的安全性分析,智能终端的用户认证技术、恶意软件识别,云计算环境下虚拟化安全分析和取证等重要研究方向。
- 同时,智能制造与工业4.0 战略提出后,互联网与工业控制系统的融合已成为当前的主流趋势,而其中工控系统的安全问题也日益凸显。

网络空间安全的四项主要内容



Network security

Wireless mobile
network secure access

Anonymous communication
and traffic analysis

User behavior
analysis

Protocol analysis
and design

3. 网络层安全

该层研究工作的主要目标是**保证连接网络实体的中间网络自身的安全**，涉及各类无线通信网络、计算机网络、物联网、工控网等网络的安全协议、网络对抗攻防、安全管理、取证与追踪等方面的理论和技术。

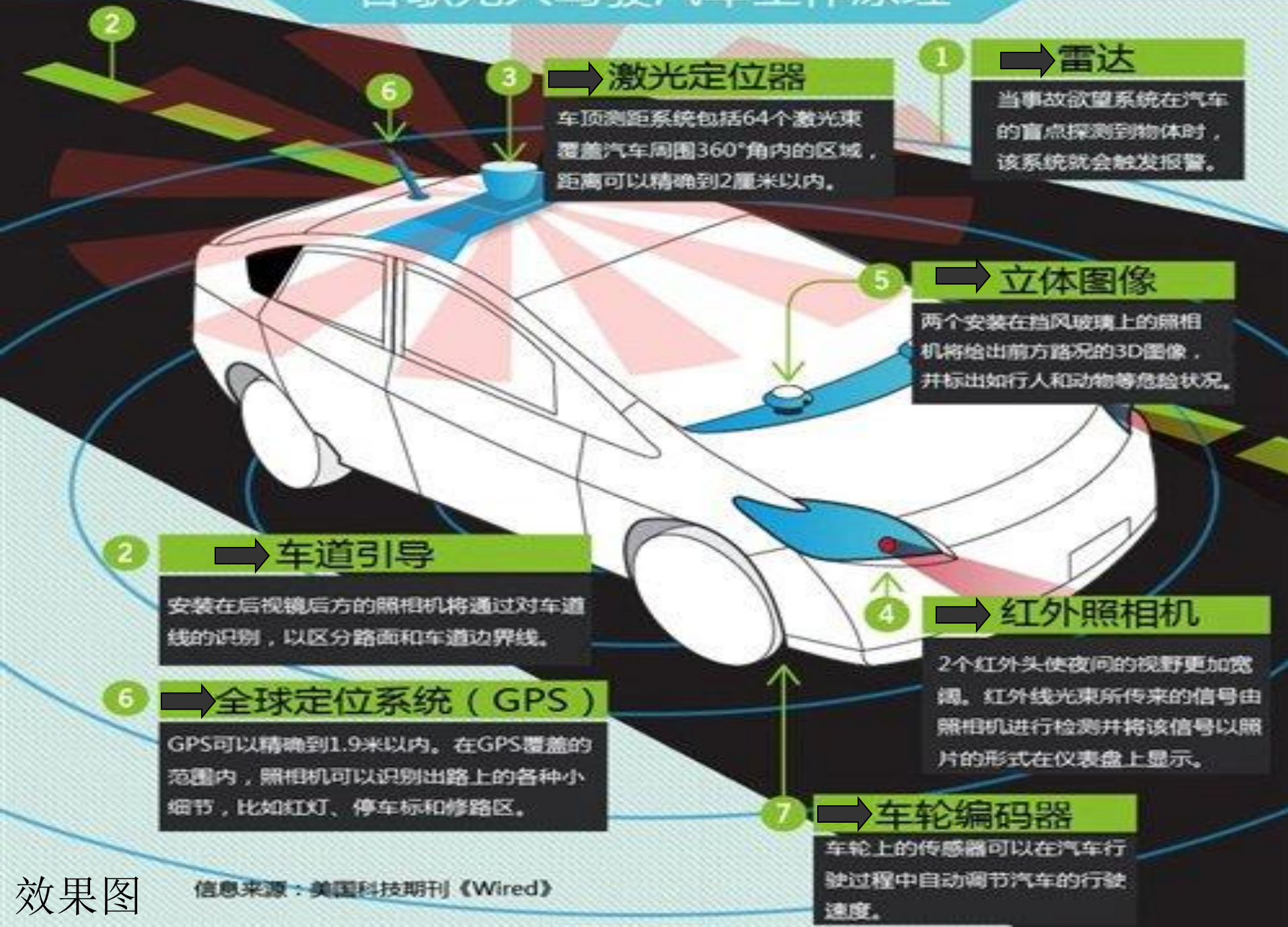
随着智能终端技术的发展和移动互联网的普及，移动与无线网络安全接入显得尤为重要。而针对网络空间安全监管，需要在网络层发现、阻断用户恶意行为，重点研究高效、实用的匿名通信流量分析技术和网络用户行为分析技术。

人工智能进展-案例分析

Google的无人驾驶汽车



谷歌无人驾驶汽车工作原理



信息来源：美国科技期刊《Wired》

效果图

网络空间安全的四项主要内容



Data security

Data privacy and
anonymity

Media content security

Information aggregation and
propagation analysis

4. 数据层安全

数据层安全研究的主要目的是保证数据的机密性、完整性、不可否认性、匿名性等, 其研究热点已渗透到社会计算、多媒体计算、电子取证、云存储等多个应用领域,

具体包括数据隐私保护和匿名发布、数据的内在关联分析、网络环境下媒体内容安全、信息的聚集和传播分析、面向视频监控的内容分析、数据的访问控制等。

第四节

网络空间安全治理的定义



网络空间安全治理的基本概念

- 治理

——治理和国家治理是源于西方的**学术概念**，从概念上而言，是“各种管理共同事务方式的总和，是不同利益得以调和的持续行动过程” [12]

——**研究上**而言，认为治理即治国理政，是一项发展性极强的管理活动和一种因时而进、因势而新的社会现象。

——**国内学者**刘振江提出的相关观点“马克思主义国家理论是习近平国家治理思想的发轫之地” [13]

- 网络安全治理是国家治理思想在网络空间的提升拓展。

网络空间安全治理的机遇和挑战

■ 全球互联网治理，又称为网络空间国际治理、网络空间全球治理，是全球所有利益相关方针对网络空间涉及的政治、经济、军事、文化、社会等各层次问题，围绕发展与安全两大方面，搭建磋商平台和机制，开展对话和磋商进程，共同制定原则、规范、规则并付诸实践，从而构建公平合理的网络空间治理体系，推动形成**网络空间命运共同体**，促进人类社会迈向更美好的未来。

机遇

网络空间越来越成为：
信息传播的新渠道、生产生活的新空间、经济发展的新引擎、文化繁荣的新载体、社会治理的新平台、交流合作的新纽带、国家主权的新疆域。

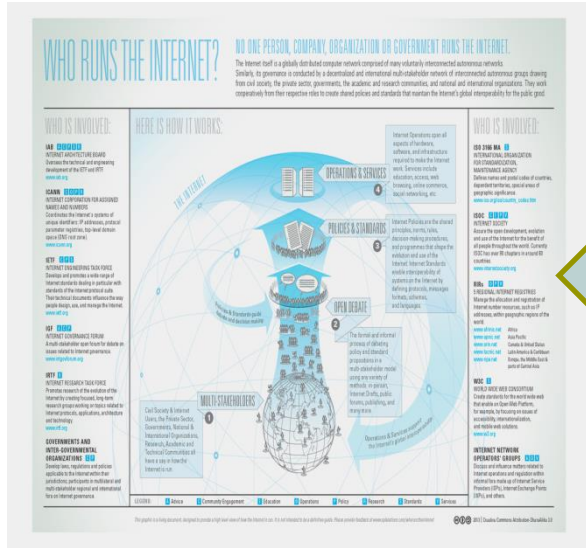
挑战

“数字鸿沟”不断拉大。关键信息基础设施存在较大风险隐患。基础资源管理体系难以反映大多数国家意愿。网络恐怖主义、网络犯罪呈蔓延之势。滥用信息通信技术时有发生。缺乏普遍有效规范各方行为的国际规则。

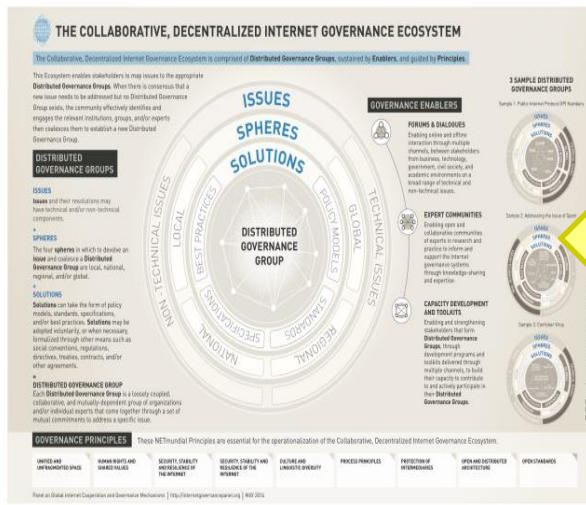
全球网络空间治理（互联网治理）历史

- 互联网空间确立，网络规模和应用领域不断扩展
- 技术社群与美国政府博弈，互联网技术组织陆续设立
- 各方全面介入治理进程，重要治理议题不断扩展

非国家行为体占据有利位置，各国主导国际秩序受到挑战



非政府机构运行全球互联网



去多边的全球互联网治理

- 受全球互联网发展的历史因素影响，非国家行为体构成的I*体系，至今仍掌握互联网基础资源分配和管理权，并主导相关技术标准和技术政策制定；国家行为体及传统多边机制在该领域发挥的作用十分有限。
- I*体系：由IETF、ICANN、ISOC、W3C、区域RIR等组成。
- 在安全、内容管理、经济贸易等国家行为体传统上主导的领域，以跨国企业为代表的非国家行为体凭借强大的技术产业实力和行业影响力，对各国及多边机制主导构建国际秩序的模式提出挑战。
- 主要表现为谷歌、脸书、亚马逊、苹果、推特、阿里巴巴、腾讯等互联网巨头建立的全球性互联网应用平台、电子商务平台，聚集了海量用户，形成了规制体系，事实上构建了网络空间的秩序

网络的开放性必然带来风险性



世界第一个计算机病毒：莫里斯蠕虫

- 该蠕虫由康奈尔大学研究生罗伯特·泰潘·莫里斯（Robert Tappan Morris）编写，于1988年11月2日从麻省理工学院施放到互联网上。“蠕虫”事件最终导致大量计算机和连接设备无法使用，许多研究机构和政府部门的网络陷于瘫痪，经济损失巨大。
- 1990年12日，纽约联邦地方法院判处莫里斯三年缓刑、400小时社区服务、10050美元罚款并支付所有监管费用。莫里斯成为美国法院依据《1986年计算机欺诈及滥用法》而定罪的第一人。



罗伯特·莫里斯
现为MIT教授

存有莫里
斯蠕虫源
代码的磁
盘



网络战：爱沙尼亚网络战



- 从2007年4月底开始，爱沙尼亚面对大规模的网络袭击。黑客目标包括国会、政府部门、银行以至媒体的网站，其攻击规模广泛而且深纵，事件在国际军事界中广受注目，普遍被军事专家视为第一场国家层次的网络战争。
- 之后，北约成立北约网络合作防御卓越中心，推出《塔林手册1.0》、《塔林手册2.0》。

攻击硬件和工控网：伊朗震网（Stuxnet）病毒事件

- 2010年9月，伊朗政府宣布，大约3万个网络终端感染“震网”，病毒攻击目标直指核设施。这预示着网络战已发展到以破坏硬件为目的的新阶段。由于被病毒感染，监控录像被篡改。监控人员看到的是正常画面，而实际上离心机在失控情况下不断加速而最终损毁，数量达1000台。



社会恐慌：乌克兰电力系统遭受攻击

- 2015年12月23日，乌克兰电力部门遭受到恶意代码攻击。据媒体报道：“至少有三个电力区域被攻击，并于当地时间15时左右导致了数小时的停电事故”；“攻击者入侵了监控管理系统，超过一半的地区和部分伊万诺-弗兰科夫斯克地区断电几个小时。”
- 安天公司分析：这是一起以电力基础设施为目标、以BlackEnergy等相关恶意代码为主要攻击工具，通过BOTNET体系进行前期的资料采集和环境预置；以邮件发送恶意代码载荷为最终攻击的直接突破入口，通过远程控制SCADA节点下达指令为断电手段；以摧毁破坏SCADA系统实现迟滞恢复和状态致盲；以DDoS服务电话作为干扰，最后达成长时间停电并制造整个社会混乱的具有信息战水准的网络攻击事件。



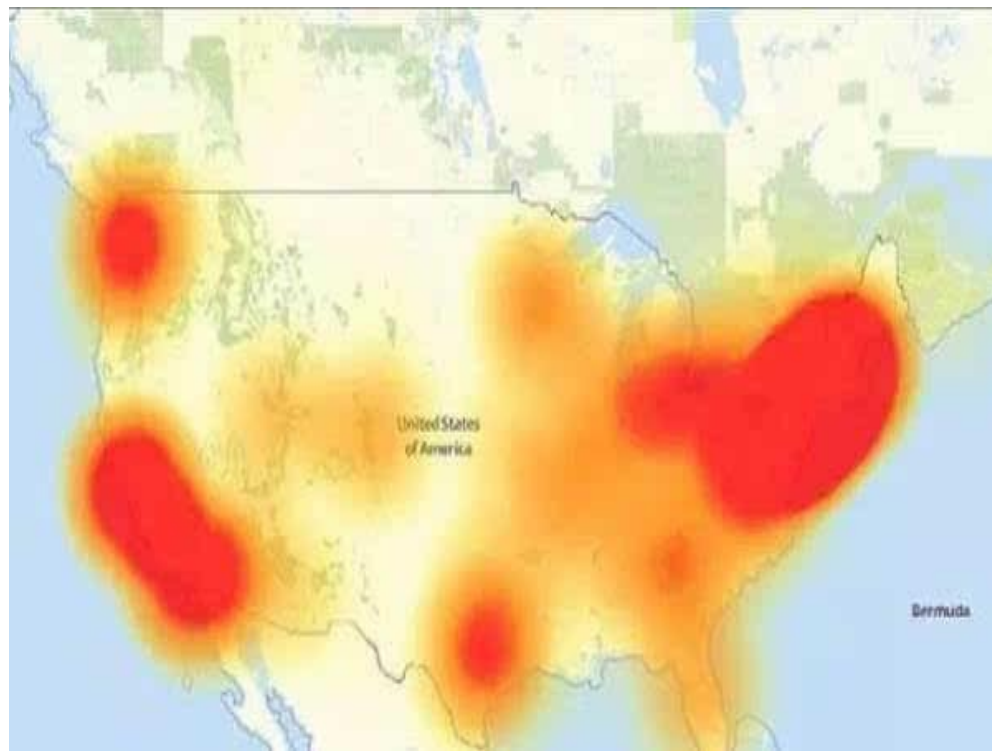
攻击内网：永恒之蓝勒索病毒全球爆发

- 2017年5月12日，“永恒之蓝”勒索病毒全球爆发，系由不法分子利用美国国家安全局（NSA）泄露的危险漏洞“Eternal Blue”（永恒之蓝）进行传播，至少150个国家、30万名用户中招，造成损失达80亿美元，已经影响到金融，能源，医疗等众多行业。中国部分Windows操作系统用户遭受感染，影响巨大。
- 2017年6月27日，全球遭受新一轮勒索病毒攻击，乌克兰切尔诺贝利核设施辐射监测系统、俄罗斯最大石油公司以及欧美多国企业纷纷中招。



美国也不能幸免：网络攻击致半个美国互联网瘫痪

- 2016年10月21日，美国遭到大规模的“拒绝访问服务”(DDoS)攻击，多个城市出现互联网瘫痪情况，包括Twitter、Shopify、Reddit等在内的大量互联网知名网站数小时无法正常访问。



个人信息保护：数据泄露事件频发



- 雅虎2017年10月披露，在2013年黑客入侵事件中，30亿个用户账号信息被盗，被盗信息包括用户姓名、电邮地址、电话号码、出生日期、密码、安全问题和答案等，是有史以来规模最大的数据泄露事件。
- 2017年9月，美国信用机构Equifax称遭黑客入侵，1.43亿用户数据在线泄露，包括社会保障号、驾照号等敏感信息。
- 2018年3月，Facebook被爆泄露5000万用户信息。剑桥分析公司通过其获取的超过5000万个Facebook用户的私人信息，提供工具辨别这些用户的性格，从而推送广告影响这些美国选举人的行为。
- 2022 上海公安

- 2017年3-7月，公安部部署开展打击整治黑客攻击破坏和网络侵犯公民个人信息犯罪专项行动，查获各类公民个人信息500余亿条。
- 2018年8月，浙江绍兴越城区警方侦破一起特大规模的数据窃取案，瑞智华胜及其关联公司在与正规运营商合作中，通过技术手段提取公民个人信息、相关账号密码、搜索的关键词等内容，涉嫌非法窃取用户信息30亿条。
- 2018年8月，网上叫卖华住集团5亿条酒店客户信息。
- 2018年10月，香港国泰航空及其全资子公司大约940万名乘客的资料曾被不当取览。包括乘客姓名、国籍、出生日期、电话号码、电邮及实际地址、护照号码、身份证号码、飞行常客计划会员号码、顾客服务备注及过往的飞行记录资料。



网络意识形态安全：欧美的反宣传法案

- 2016年11月23日，欧洲议会通过了《欧盟反击第三方宣传的战略传播》建议案。它号召欧盟各成员国采取措施反制第三方宣传。所谓“第三方宣传”：一是恐怖主义，二是犯罪组织，三是俄罗斯媒体《今日俄罗斯》。
- 2016年12月23日，美国总统奥巴马签署了《波特曼-墨菲反宣传法案（Portman-Murphy Counter-Propaganda Bill）》。美国国防部将在2017年获得额外预算，专门建立一个反宣传中心，对抗外国对美国的宣传。该法案的目的是提升美国和盟国的整体防卫战略，反制来自俄罗斯、中国和其他国家的政治宣传与谣言，并且防止海外盟国变成其它国家的傀儡，帮助盟国获得更加真实的信息，保护外国民众免受宣传洗脑。该法案的目的就是为了创造一种“能打赢思想战的更全面、更积极的方式”。

美国网络霸权：棱镜门事件

- 2013年6月，前中情局（CIA）职员爱德华·斯诺登披露美国国家安全局代号为“棱镜”的秘密项目。美国国家安全局和联邦调查局通过进入微软、谷歌、苹果、雅虎等九大网络巨头的服务器，监控美国公民的电子邮件、聊天记录、视频及照片等秘密资料。
- 监听**欧盟**机构，并入侵欧盟电脑网络，且已达5年之久。
- 针对**中国**个人和机构的网络攻击，并把中国领导人和华为公司列为目标。攻击的目标还包括商务部、外交部、银行和电信公司等。
- 奥巴马辩称，情报机构的工作是“为了更好地认识世界”。
- 国务卿克里则辩称，监控是出于国家利益考虑，“各种各样的情报对维护国家安全都有好处”。



中美网络空间博弈：美国起诉中国军官事件

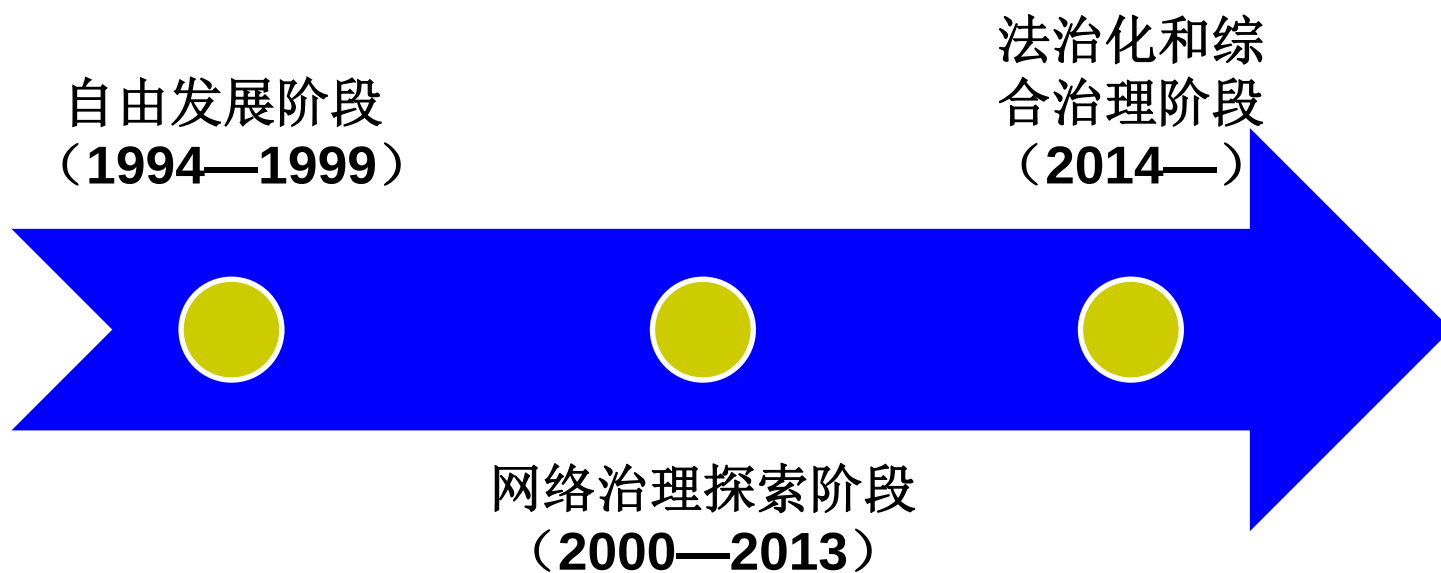
- 2014年5月19日，美国司法部以所谓“网络窃密”为由，起诉5名中国军官。指控中国军方人员侵入美国企业窃取商业秘密。
- 网络空间已成为最容易引起中美争论的领域之一，在网络空间中的紧张局势是导致两国关系进一步恶化的主要原因之一。



中国的网络空间安全治理主张

- ——主权原则应适用于网络空间
 - 应该强化联合国在网络空间安全治理中的地位
 - 反对网络空间单边主义与双重标准
 - 倡导平等共治的命运共同体模式
- 为了更好地争取对网络空间安全治理的话语权，中国还应从外交方式、理论研究、国内网络治理能力，以及重视非国家行为者等角度提升在网络空间安全全球治理中的因应之道[14]。

我国网络治理的历程



中国的网络空间安全治理的主要体现点-4

- 1.倡导网络空间命运共同体理念:

提出全球互联网国际治理的“四项原则”和“五点主张”，丰富“网络主权”概念，倡导“网络空间命运共同体”理念，发布《网络空间国际合作战略》、《网络空间安全战略》

- 2.举办世界互联网大会备受瞩目:

- ✓ 主动打造互联网治理国际平台，提升规则制定权和国际影响力
- ✓ 已成功举办五届大会，加快了网络主权、网络空间命运共同体等理念的国际传播

- 3.网络空间交流与合作不断深化:

互联网国际交流与合作不断深化，“21世纪数字丝绸之路”建设初见成效

- 4.互联网机构任职取得可喜进展

习近平网络空间安全治理观

重要讲话:

- 网络安全和信息化是**一体之两翼** 驱动之双轮。必须统一谋划 统一部署 统一推进、统一

一张图读懂习近平演讲

演讲内容

1 一个目标

要让互联网发展成果惠及13亿多中国人民，更好造福各国人民。



2 两大支点

不同国家和地区信息鸿沟不断拉大，现有网络空间治理规则难以反映大多数国家意愿和利益；

世界范围内侵害个人隐私、侵犯知识产权、网络犯罪等时有发生，网络监听、网络攻击、网络恐怖主义活动等成为全球公害。

3 三大战略

网络强国战略

国家大数据战略

“互联网+”行动计划

4 四项原则

尊重网络主权

维护和平安全

促进开放合作

构建良好秩序

5 五点主张

加快全球网络基础设施建设，促进互联互通。

打造网上文化交流共享平台，促进交流互鉴。

推动网络经济创新发展，促进共同繁荣。

保障网络安全，促进有序发展。

构建互联网治理体系，促进公平正义。

1发展要同

2计成本追

3展、依法

运行的性能

《网络
管理、

《网络
，并仿

习近平网络空间安全治理观

● 1. “一体两翼双轮驱动”的网络安全战略观

2014年，习近平在中央网信领导小组首次会议上指出，网络安全和信息化是一体之两翼，驱动之双轮。所谓“一体”，即网络强国的目标主体，这是国家战略，也是目标愿景；所谓“两翼双轮驱动”，即“网络安全”和“信息化”。这犹如鸟之两翼、车之两轮，两者双翼并展、双轮共驱，是网络强国主体目标的实现路径。



[16] 谢永江.习近平总书记的网络安全观[J].中国信息安全,2016(05):34-35.

[17] 张绍荣,代金平,张晓歌, 习近平的网络安全治理观[J].重庆邮电大学学报: 社会科学版.2017年5期.

习近平网络空间安全治理观

● 2. “网络空间命运共同体” 的网络安全共建观

- 站在全球互联网发展治理的高度，2015 年习近平在第二次世界互联网大会上首次提出了“构建网络空间命运共同体”的共建主张，为全球网络安全治理指明了道路和方向，得到了世界各国的纷纷响应。网络空间命运共同体虽然构建于虚拟的网络空间，但依赖于现实世界人们的共同推动和努力。因为无论是网络空间，还是现实世界，其安全治理推动的主体都是人民或网民，这就决定了在虚拟空间与现实世界欲构建的命运共同体之间，必然存在着紧密的逻辑联系。

习近平网络空间安全治理观

- 3. “以人民为中心发展”的网络安全利益观
- 互联网因汇聚不同地域的人们走进同一个世界而成为网络空间，以人民为主体的广大网民是网络空间的主人，人民的利益、网民的诉求是网络安全治理的最大利益。习近平反复强调：“国家安全工作归根结底是保障人民利益，要坚持国家安全一切为了人民、一切依靠人民，为群众安居乐业提供坚强保障。”

习近平网络空间安全治理观

- 4. “核心技术自主创新”的网络安全技术观
- 习近平指出：“网络安全的本质在对抗，对抗的本质在攻防两端能力较量。”互联网核心技术是我们最大的“命门”，核心技术受制于人是我们最大的隐患。因此，我们必须牢牢树立核心技术自主创新的网络安全技术观，抓紧突破网络发展的前沿技术和具有国际竞争力的关键技术，构建起以自主创新为主、引进消化吸收为辅的网络技术创新体系。”

习近平网络空间安全治理观

● 5. “尊重网络主权反对霸权”的网络安全国家观

- 网络主权是国家主权在网络空间的拓展和延伸。放眼网络空间，互联网在带来利好的同时，也使网络安全风险日益突出，网络主权随时面临威胁和挑战。习近平强调：“要理直气壮地维护网络空间主权，明确宣示我们的主张。”由于网络核心技术一直为发达国家所掌握，服务器分布也主要集中少数发达国家手中，所以在较长的时期内，网络空间被西方大国主导，表现出网络霸权。基于维护国家安全，网络安全治理坚持尊重网络主权，反对网络霸权，坚持多样化的发展道路，充分尊重各自选择的网络运行模式和管理政策机制，显得尤为重要。

习近平网络空间安全治理观

● 6. “聚天下网信英才而用之” 的网络安全人才观

- 人才资源是国家的第一资源，是实现网络安全长治久安的关键。习近平指出：“人才是第一资源”，“要聚天下英才而用之，为网信事业发展提供有力人才支撑”。互联网是青年人的天地，网络空间既是高层次网信人才聚集之地，也是高层次网信人才培养之地，理应不忘初衷培养人才，尤其在培养青年网信人才上下大功夫，努力培养更多优秀学生在掌握核心技术网信创新人才。要征招一流的优秀网络空间安全学院培养未来人才，为网络发展储备优质的后备人才。

第五节

网络空间主权



我国网络空间的主权主张-法律三驾马车-网络安全法-数据安全法-个人信息保护法

- 国家主权具有以下“444”特征。
- 四个基本要素：领土、人口、资源与政权；
- 四项基本权力：独立权、平等权、自卫权与管辖权；
- 四条基本原则：尊重主权、互不侵犯、互不干涉内政、主权平等。
- 网络空间主权作为国家主权的一个延伸，自然也继承了这些特征

[2] 方滨兴. 论网络空间主权[M], 北京:科学出版社. 2007年9月1日。

[3] 方滨兴, 邹鹏, 朱诗兵. 网络空间主权研究[J]. 中国工程科学, 2016, 18(6):1-7.

我国网络安全法的基本原则

- （一）网络主权原则
 - 所谓网络主权，简单来讲，就是一国国家主权在网络空间中的自然延伸和表现。
 - 对内，网络主权指的是国家独立自主地发展、监督、管理本国互联网事务；
 - 对外，网络主权指的是防止本国互联网受到外部入侵和攻击。



其他国家对于网络空间主权的理解

- 近些年出现在网络空间中的事例，反映出国家主权事实上已经施加在网络主权之上：
 - 美国通过没收域名来打击盗版[177]，英国封锁侵权网站[178]，德国对互联网传播非法信息的过滤要求[179]，印度政府电信部屏蔽网站[180]，新加坡打击宣扬极端主义言论[181]，韩国打击散布网络谣言的行为[182]，法国打击网络种族主义行为[183]，以色列打击网络赌博行为[184]等。事实上，美国设立网军，也是定位在保护领网。
- “利益攸关方”的提法**及其本质**：
 - 2003年12月12日，联合国信息社会世界高峰会议《原则宣言》明确提出：与互联网有关的公共政策问题的决策权是各国的主权。对于与互联网有关的国际公共政策问题，各国拥有权利并负有责任[185]。美国的《爱国者法案》授权执法部门要求美国的互联网运营商给予情报方面的配合，充分表明了政府的作用与地位。

简单小结

■ **回顾：**互联网发源于美国。TCP/IP协议创造了互联网资源，网络空间建立。资源是诸多治理问题的原点和开端，背后是技术路线的竞争。随着互联网的普及，治理圈从美国学术、技术界，扩展到美国，再扩展到全球。治理议题扩展，治理领域延伸。

■ **当前：**互联网成为最重要的社会与经济平台。各方积极介入治理问题。全球互联网治理体系正进入格局转型期、矛盾凸显期、利益调整期。治理热点你方唱罢我登场，IANA职能监管权移交后资源问题热度下降，人们视线转移。各方不断尝试建立国际规范、规则。

■ **展望：**互联网下半场开启，工业（产业）互联网的网络技术路线竞争进入关键阶段，新型互联网资源的治理热度不断升高。宏观上看治理，旧的问题还没解决，新的问题接踵而至，局面更复杂。数字经济发展，互联网问题成为博弈的筹码。

谢谢大家！

